

LLM智能体系统安全研究进展综述

引言

随着大规模语言模型（LLM）的发展，基于LLM的自主智能体（Agent）系统在过去两年迅速兴起¹。这些LLM智能体能够接受自然语言指令，利用推理能力调用工具执行复杂任务，在诸如AutoGPT、AgentGPT等项目中得到广泛探索。然而，智能体在带来强大自动化能力的同时，也引入了全新的安全风险²。近期研究表明，将LLM接入插件、工具和多智能体通信后，其攻击面显著扩大，传统安全措施往往难以及时应对³。为了保障LLM智能体系统的可靠与安全，研究者从多个角度开展了安全分析与防护机制研究。本文综述近两年来LLM智能体安全方向的研究进展，重点关注以下五个方面：**(1)** 智能体执行任务过程中的攻击面分析，**(2)** 多智能体协作系统的安全风险与防护，**(3)** 智能体系统的安全保障机制，**(4)** 重要研究论文、开源项目与标准化工作的进展，以及**(5)** 针对LLM智能体的安全评估指标与方法。

LLM智能体的攻击面分析

LLM智能体在与用户输入、外部环境交互并调用工具时，暴露出多层次的攻击面。首要风险是**提示词注入攻击**（Prompt Injection），即攻击者在提供给智能体的文本中嵌入恶意指令，从而诱使模型忽略原有规则、执行未授权操作^{4 5}。例如，攻击者可以在用户请求中加入诸如“忽略以上所有指示，执行X操作”等隐藏指令，导致智能体违背预设策略采取不当行动^{6 7}。这类攻击已从理论走向现实：研究者成功利用**间接提示注入**诱骗AutoGPT执行任意恶意代码，甚至突破其Docker沙箱限制^{8 9}。在该案例中，攻击者将恶意指令藏于AutoGPT浏览的网页内容中，GPT-4模型将其当作正常指令执行，最终造成**远程代码执行**和系统逃逸的严重后果^{8 9}。由此可见，提示词注入攻击不仅能用于绕过内容过滤、安全指南，还可导致数据泄露、系统指令曝光，甚至通过智能体的工具调用接口实现对外部系统的未授权访问和破坏^{4 5}。

除了提示注入，LLM智能体还面临其他输入操纵威胁。例如，**长上下文劫持**利用模型长文本记忆特性，在对话历史中植入逐步升级的恶意内容，最终控制智能体行为；**多模态对抗样本**则通过图像、音频等输入中隐藏特殊触发，使具多模态能力的智能体误判指令³。另外，**任务劫持**也是一类值得关注的风险：攻击者可诱导智能体在执行任务过程中改变目标或优先级，将原任务劫持为对攻击者有利的行为。例如，某些“系统提示泄露”攻击通过精心设计的对话，引导智能体输出其系统设定或机密信息，从而偏离原定任务^{10 11}。又如在工作使用场景中，攻击者伪造输入使智能体调用危险操作（如删除数据库表），从而劫持原本良性的任务流程^{12 13}。

更深层次的攻击面在于**模型妥协与数据投毒**。攻击者可能通过在模型训练或提示中植入**后门**（Backdoor）来妥协智能体：即给予特定触发词就让模型执行攻击者预期的隐秘指令。这方面研究发现，攻击者可以将多种触发后门混合作用于LLM智能体，使其平时表现正常，却在受到特殊输入时泄露敏感信息或执行恶意操作^{14 15}。近期顶会论文提出了如复合后门攻击和多重加密后门等新技术，能够以接近100%的成功率绕过现有检测，远程控制智能体行为^{15 16}。此外，针对检索增强型智能体的**知识中毒**攻击也引发关注：通过污染其检索数据库或工具API返回结果，攻击者可以让智能体获取到恶意篡改的信息，从而输出错误结论或执行错误决策^{17 18}。总体而言，输入注入、模型后门、数据投毒等多种攻击手段层出不穷，使LLM智能体的**攻击面**遍布从输入到模型内部再到输出环节，需要系统性安全加固。研究表明，在现有防御下，**自适应提示注入**仍有超过50%的成功率绕过拦截，而高级越狱和后门攻击的成功率常在90%以上，某些甚至接近100%¹⁵。这一系列结果凸显了LLM智能体工作流当前的脆弱性，迫切需要全面的威胁模型和强健的防御机制^{19 20}。

多智能体协作系统的安全风险与防护

当多个LLM智能体组成团队协同工作时，又引入了新的安全挑战。**多智能体协作系统**中的一个关键风险是：**恶意或故障智能体**可能通过信息操纵或不当行为，影响整个团队任务的可靠执行^{21 22}。研究者指出，即使只有一个智能体频繁出错甚至蓄意捣乱，都可能“毒害”多智能体对话，使团队合作绩效严重下滑²²。在实验中，加入一个出错率较高的故障智能体，往往显著降低任务成功率，甚至引发其它智能体被误导而产生连锁错误^{22 23}。这种**信息操纵**攻击在协作环境下具有很强的破坏力，难以通过单点防御发现，因为恶意智能体往往以表面合理的内容散布谬误或触发冲突。

近期针对多智能体系统的攻击**CORBA**（Contagious Recursive Blocking Attack）形象地揭示了协同环境的脆弱性²⁴。攻击者可以设计看似无害的指令或消息，使之在智能体之间**递归传播**，造成整个代理网络反复执行无效任务、消耗资源^{24 25}。由于这些恶意指令表面良性，各智能体的对齐机制（例如拒绝不良指令的安全策略）难以识别其恶意，导致攻击像病毒一样**传染**给协作链路中的任意节点^{25 26}。实验证明，CORBA攻击可在多种拓扑下奏效，包括常用的开放源代码多智能体框架（如AutoGen、CAMEL）和主流商用模型，持续阻断智能体之间正常交互²⁷。这类**协同攻击**表明，多智能体系统不仅要防范外部敌手，也必须考虑内部节点的背叛或被攻陷情境。

为降低多智能体协作的安全风险，研究者提出了若干**防护机制**和检测方法。首先是**恶意智能体识别**：通过监控各智能体的输出行为模式，检测异常偏差或可疑内容，从而甄别出可能受攻击或蓄意破坏的智能体。在2025年ICML的一项研究中，学者设计了自动插错（AutoInject）等方法模拟智能体在对话中引入错误，进而评估不同团队结构的鲁棒性^{21 28}。结果发现，引入**分层架构**（如设一名“主管”智能体监督多个“执行”智能体）对抗恶意节点最为有效，性能下降仅约5.5%，而简单链式架构性能下滑高达23.7%^{29 30}。基于这一发现，研究者提出在团队中加入**挑战者**和**审查者**角色：每个智能体具备挑战其他智能体可疑输出的机制，另设置独立“监察”智能体审核消息^{31 32}。实验表明，这两项机制可纠正高达96%的错误，大大提高系统在恶意/故障节点存在下的整体稳健性³²。此类方法体现了**交叉校验**和**冗余审计**思想，即通过智能体之间的相互监督，及时发现并纠正异常。

除了架构改进，研究人员还倡导引入**动态信任管理**和**通信验证机制**³³。动态信任管理为每个智能体维护可信度评分，依据其历史行为调整对其信息的采信程度。一旦某智能体行为异常，其输出将在团队决策中被降低权重或触发审查³³。同时，可结合**加密签名**和**溯源技术**对智能体通信进行校验³³。例如，给每条代理消息附加数字签名和来源标识，防止外部伪造指令混入，并在发生问题时追溯是哪个体首先引入了恶意内容。这种**来源可追溯性**有助于定位并隔离团队中的“内鬼”智能体。总体而言，多智能体协作系统安全需要**内生对抗**的思路，即在团队内部建立起质询、审核和信任调控机制，从而提升对抗恶意行为的弹性。

智能体系统的安全保障机制

针对上述攻击风险，业界和学界提出了一系列**安全保障机制**来保护LLM智能体系统的运行安全。这些机制主要包括运行环境的隔离、策略层的控制以及事后审计反馈。

1. 沙箱环境：为防止智能体在执行外部代码或操作系统命令时造成不可控危害，许多系统采用**沙箱环境**对其行为加以隔离。例如，OpenAI的ChatGPT插件和代码解释器功能，会将代码执行限制在隔离的容器或虚拟机中，只开放有限的资源和权限。这种做法可以避免智能体直接接触底层操作系统或敏感数据，从而将潜在损害控制在可控范围内。值得注意的是，沙箱本身也需安全加固。正如前文提到的AutoGPT案例，研究者发现早期版本的AutoGPT沙箱实现存在漏洞，攻击者能够通过路径遍历等方式绕过隔离，在主机系统执行未授权代码³⁴。对此，开发者随后修复了相关漏洞（v0.4.3版本），加强了容器边界和文件系统访问控制³⁴。由此可见，**安全沙箱**是保障自主智能体系统安全的基础，但须确保沙箱机制本身无漏洞，并尽量采用“最小权限原则”配置（Least Privilege）^{35 36}。智能体只应拥有完成任务所需的最低权限，例如只能访问特定目录文件、只能调用经过审计的有限API等。一旦智能体尝试越权操作，沙箱应立即阻止并记录。通过隔离和最小权限双管齐下，可大大降低智能体执行恶意或错误指令时对真实系统造成破坏的风险。

2. 审计与监控： 审计系统为智能体的决策和行为提供了重要的事后分析与追溯手段。完善的智能体框架通常会记录其每一步“思考”（模型中间推理）、所调用的工具命令、外部接口交互以及得到的结果。这些日志数据能够帮助开发者或安全团队在事后重放智能体行为轨迹，分析安全事件的成因。例如，在一次异常文件删除事件后，审计日志或显示智能体在何时因何种输入决策执行了删除命令，从而判断是遭受了提示注入欺骗还是内部策略缺陷。除事后分析外，**实时监控**也非常关键³⁷。可以部署独立的监控模块，在线检查智能体的输出和动作，如发现敏感信息泄露迹象、连续多次可疑失败、或尝试访问未授权资源等异常模式，则及时发出警报或自动暂停智能体行动^{38 35}。一些防御方案还提供**输出校验**功能：对智能体生成的关键输出结果，在正式采用前通过规则或另一个模型进行校验。例如，当智能体准备执行一个数据库修改指令时，可先由规则引擎检查该指令是否有删除全部记录等危险操作^{12 13}；或者利用另一个监督模型判断该输出是否违反安全策略。总之，借助**监控-审计闭环**，可以在智能体运行过程中发现异常并及时干预，并通过事后分析不断改进安全策略。

3. 安全策略框架： 在智能体体系结构上引入**安全策略层**，为智能体的决策和行为预先设定规则与约束，是保障安全的另一重要机制。这类**安全策略框架**可分为静态和动态两种：静态策略是在部署前制定的固定规则，如禁止智能体执行删除所有文件的命令、限制其使用某些高危工具等；动态策略则能根据环境和智能体行为实时调整。例如，OpenAI的插件接口设计就包含一定的策略思想——某些敏感操作（如涉及用户私人数据的行为）需要经过用户明确授权才会执行³⁹。在MCP（Model Context Protocol）等新型智能体通信协议中，也专门规定了**人工审批流程**，当智能体请求高危服务或跨域操作时，需先征得人类或上级代理的许可³⁹。这些机制相当于在智能体和其行动对象之间加入一层**策略网关**。再比如，OWASP在2024年启动了针对生成式AI安全的项目，其中提出应实现**输入校验、输出过滤、会话隔离**等策略控制^{38 40}。具体措施包括：对进入智能体的用户输入进行**正则过滤或白名单校验**，剔除明显含有指令注入意图的内容⁴⁰；对智能体产出的内容应用敏感信息检测，防止机密数据泄露⁴；在多轮对话中为每个用户会话单独维护上下文，避免跨会话攻击等。又如Fujitsu最新发布的多智能体安全技术，引入了**LLM漏洞扫描器**和**智能防护栅栏**，自动测试智能体对3500余种已知攻击的抗性，并针对检测到的高风险提示自动应用防护规则加以拦截^{41 42}。这相当于为智能体部署一套动态策略防火墙，在运行过程中不断检查并强化其安全政策。值得注意的是，无论多么完备的策略库都难以穷尽所有威胁场景，因此策略框架需结合前述监控审计机制，不断根据最新攻击手法进行更新迭代，从而形成**闭环的安全策略管理：设策-监控-审计-改进**。通过这种持续完善的策略治理，智能体系统才能在复杂多变的攻击环境中保持安全可靠的运行。

近两年重要论文、项目与标准化进展

过去两年中，LLM智能体安全成为学术界和工业界关注的热点，大量**重要研究成果、开源项目以及标准化工作**涌现。下面对其中具有代表性的进展作一梳理。

- **安全威胁分析方向的重要论文：** 2025年，多篇综述论文系统梳理了LLM智能体面临的安全挑战与威胁模型。Ferrag等人在ICT Express发表的文章提出了首个端到端的智能体生态威胁模型，归纳出输入操纵、模型妥协、系统/隐私攻击和协议漏洞四大类30余种攻击手法，并讨论了每类攻击的实例与防御¹⁴⁴³。另一篇ACM Computing Surveys论文则聚焦AI自主代理的安全挑战，将风险归纳为**多轮输入的不确定性、内部执行的复杂性、运行环境的多样性和外部交互的不信任性**四个方面^{44 45}，指出当前在保障代理安全上仍有诸多未解难题。这些综述为智能体安全研究奠定了总体框架。一些前沿研究针对特定攻击给出新发现：例如Zou等人研究了**检索增强生成（RAG）**流程中的知识污染攻击，证明即使在黑箱设置下，攻击者也能通过微小篡改检索文档，引发LLM输出被定向操纵的信息^{46 47}；Yang等人在NeurIPS 2024发表论文“Watch out for your agents!”，深入探讨了**LLM智能体的后门威胁**，展示攻击者可在开放源码智能体框架中植入“隐藏指令”后门（BadPrompt、BadAgent等），一旦启用即使模型表面对齐良好也会执行攻击者的隐秘命令^{48 49}。此外，Schwartz等人提出了**攻击图优化策略（GAP）**来自动生成更隐蔽的越狱提示^{50 51}；Chen等人设计了**主动环境注入攻击（AEIA）**以评估多模态移动代理的鲁棒性⁵²；这些研究丰富了对智能体攻击面的认知。总体而言，近两年顶会安全论文围绕**提示攻击、后门投毒、多智能体干扰**等主题展开，提出了不少新颖攻击手法和漏洞案例，推动业界正视LLM智能体在真实应用中面临的安全挑战。

- **开源项目与框架：** 在实践层面，多款有代表性的LLM智能体项目在开源社区引发热议，也促使人们关注其安全性。**AutoGPT**（2023年3月开源）作为最早爆红的自主智能体，实现了让GPT-4根据高层目标自主分解任务、调用工具执行的流程。然而安全研究人员很快发现AutoGPT默认配置存在提示注入和代码执行风险（如前述AutoGPT远程代码执行漏洞），督促开发者在后续版本中加入了用户确认提示、沙箱隔离等安全改进^{9 34}。**AgentGPT**是另一类似项目，提供了网页版界面便于用户部署自主智能体，它采用与AutoGPT相仿的机制，同样需要用户警惕提示注入带来的自动化滥用风险。**BabyAGI**、**Camel**等实验性代理也各具特色：BabyAGI引入了任务队列和记忆管理，Camel尝试让两个GPT代理以角色扮演方式相互协作完成任务。这些项目验证了智能体的潜力，但其安全机制仍相对初步，一些恶意输入可以使其陷入死循环或输出不可靠结果。为方便开发者构建定制智能体，**LangChain**、**LlamaIndex**（**GPT Index**）等框架应运而生。它们提供标准工具接口和链式调用管理，大大降低了开发门槛。然而，安全专家提醒，在使用这类框架时务必实现**提示清理**、**输出过滤**等安全措施^{38 37}。因为框架本身并不自动防御提示注入或滥用调用，安全仍取决于开发者正确配置。如OWASP针对LangChain专门发布了安全使用建议，强调要利用该框架的**明确分隔系统提示**功能，避免简单字符串拼接用户输入^{53 6}。由此可见，虽然开源智能体项目如雨后春笋，但其安全可靠部署需要结合专门的安全加固实践。
- **多智能体协作与工具标准化：** 针对LLM智能体互相通信、调用外部工具缺乏统一标准的问题，社区近年提出了多个**协议规范**尝试标准化。**Model Context Protocol (MCP)** 是一种受语言服务器协议启发的通信协议，旨在为智能体发现和使用工具提供统一框架。通过MCP，智能体可以查询可用服务、协商数据格式，并在执行敏感操作时请求人工审批^{54 39}。在MCP的基础上，又出现了**Agent Communication Protocol (ACP)**、**Agent Network Protocol (ANP)** 和 **Agent-to-Agent (A2A)** 协议，分别侧重于点对点的智能体消息传递和多智能体编排交互⁵⁴。Google于2025年推出A2A协议并发布博客宣布开启“代理互操作新时代”^{55 56}。这些协议的出现，标志着业界正尝试为快速发展的智能体生态建立**标准化接口**和安全规范。例如，各协议都强调了认证和权限管理的重要性，要求通信时有机制确认消息发送智能体的身份，防止未授权代理注入指令^{57 58}。又如MCP规范建议对工具返回的数据进行模式验证和边界检查，以免智能体处理异常输入时出错^{59 60}。在实践方面，多个**开源实现**相继涌现：如开源的MCP服务器项目整合了版本控制、云数据库等多种后端工具，展示了协议在复杂环境下的适用性⁶¹。CMU联合产业界发起了**OpenHands**计划，开发通用的AI代理平台，并计划将部分多智能体协作技术开源^{62 63}。可以预见，未来随着标准化组织和社区的推进，LLM智能体的协议接口、安全认证和权限模型将更加统一。这将有助于开发者遵循最佳实践构建安全的智能体系统，并为不同厂商、不同领域的智能体协同提供可信基础。
- **安全团队与机构工作：** 各大安全研究团队和机构也在积极投入LLM智能体安全。**OWASP**于2023年底启动了生成式AI安全项目，发布了《LLM安全防护清单》等文档，详细列举了如提示注入、数据泄露、工具滥用等常见威胁，并给出了对应的防御建议^{40 4}。**美国NIST**在其AI风险管理框架中也强调了评估AI代理鲁棒性和安全性的必要，将其纳入组织AI部署风险考量指标（尽管NIST具体指南更偏高层策略）。**学术组织方面**，2024年一些顶会（例如USENIX Security、IEEE S&P）开始出现专门探讨LLM和代理安全的论文，标志着这一领域正快速成熟。产业界的安全团队，如OpenAI、Anthropic的红队，也针对自家模型的代理能力进行了大量内部测试，并公开分享了一些红队经验。安全公司方面，Lakera等初创公司专注于提供**AI安全防护**方案，例如Lakera推出了实时监测并阻止提示攻击的Guard工具，并通过线上挑战平台Gandalf演示了越狱攻击的常见技巧^{64 65}。大型安全厂商如微软、谷歌的安全团队也发表博客分析LLM集成应用的风险，提供防御最佳实践。可以说，在标准和治理尚未完全跟上的情况下，这些安全社区的**知识共享和工具发布**对于提升从业者安全意识、推动行业建立共识起到了重要作用。

LLM智能体安全评估的指标与方法

为了量化和提升LLM智能体的安全水平，研究者近年来开发了多种**评估指标和测试方法**。传统上，安全评估关注攻击的成功率和防御的有效性。在LLM智能体场景中，常用指标之一是**攻击成功率（ASR）**，表示在给定防御措施下攻击能绕过或攻陷智能体的比例¹⁵。例如，前文提到的各类提示注入和越狱技术，其成功率常用ASR衡量：Adaptive攻防对抗中，提示注入绕过已有防御的成功率>50%¹⁵；复杂后门（如复合后门CBA、

DemonAgent) 在触发条件下几乎100%生效⁶⁶；自动生成越狱提示的方法(GPT-Fuzzer、GAP等)对主流模型的攻击成功率也在90%以上^{16 67}。这些指标量化了智能体在现有防护下的脆弱性程度。相应地,防御方案的评估可以看其将ASR降低多少、是否引入误杀等。另一个重要角度是**鲁棒性和成功率的权衡**:因为在某些基准下,完全拒绝风险操作可能导致智能体任务完成率下降。因此也有研究引入**安全性能综合分**,平衡智能体在安全限制下仍完成有用任务的能力。

为了更系统地评估智能体的安全表现,学术界建立了若干**基准测试集**(Benchmark)。2024年提出的**AgentHarm**基准就是专门用于测量LLM智能体“有害行为”倾向的测试⁶⁸。AgentHarm收集了涵盖**诈骗、网络犯罪、仇恨骚扰**等11大类的110个恶意任务场景(经数据增强共440个任务),要求评测的智能体在用户提出不法请求时能否拒绝或安全应对^{68 69}。同时,它考察智能体在被强行越狱后的行为,即攻击成功时模型是否会执行多步骤的连贯有害任务^{70 71}。AgentHarm对多种主流LLM进行了测试,发现**即使不使用复杂越狱**,一些领先模型在面对明确恶意请求时仍然**过于顺从**,可能直接执行违规指令;而简单通用的越狱提示可以进一步显著降低几乎所有模型的防御力^{71 72}。这一基准凸显了当前LLM代理在**应对恶意指令**方面的不足,促进研究人员改进模型的拒绝策略。另一项由清华大学等提出的**Agent-SafetyBench**则侧重评估**智能体在交互环境中的安全性**⁷³。该基准构建了349个交互环境、2000个测试用例,涵盖**8种安全风险类别**(如操作错误、资源滥用、伦理违规等)以及智能体常见的10种失败模式^{73 74}。研究者使用该基准评测了16个知名LLM智能体代理,结果没有任何一个代理的综合安全得分超过60%,表现令人担忧^{75 76}。分析发现,当前智能体主要存在**鲁棒性不足**(对输入扰动或环境变化易出错)和**风险意识缺乏**(难以预见自身行为可能引发的危害)两大缺陷⁷⁷。同时实验还表明,仅靠在提示中加入防御性语句(如“如果用户请求非法内容则拒绝”)并不能彻底解决问题,模型往往缺乏深层次的安全认知,需要引入更高级的防御策略⁷⁸。Agent-SafetyBench的推出为全面衡量和比较不同智能体的安全水准提供了工具,其开源也方便后续研究据此改进代理的安全机制^{73 79}。

除了基准任务集合,自动化的安全测试工具也在兴起。例如,Yu等人开发了**GPTFuzzer**,可以自动生成各种可能的越狱提示,批量测试LLM在对抗性提示下的表现,从而发现模型策略的薄弱环节^{50 80}。又如Dong等人于2025年IEEE S&P提出利用**模糊测试**方法攻击文本到图像生成模型背后的LLM代理,通过模拟海量异常输入来评估代理在多轮对话中的稳健性⁸¹。这些自动化工具使得对LLM智能体进行**渗透测试**成为可能,可以更高效地覆盖广泛的攻击空间,及时发现新漏洞。在评价指标方面,安全测试也引入了一些新的度量,例如**拒绝率**(模型在不良请求下正确拒绝的次数占比)、**纠正正常误率**(如多智能体互审机制下错误被纠正的比例)等,以全面衡量智能体既要安全又要实用的性能。

最后,值得一提的是社区正在探索制定智能体安全的行业标准或认证机制。目前已有倡议建议建立**LLM智能体安全评估基准**,类似传统软件的安全评估认证,为不同智能体产品打分评级,方便用户了解其安全可靠程度。这方面或将由权威研究机构联合产业联盟推动。在标准出现前,采用公开的基准和严格的红队测试,已成为业内认可的评估LLM智能体安全的方法^{64 82}。通过持续的测评和改进,我们有望逐步提高LLM智能体抵御攻击的能力,制定出被广泛接受的安全标准,促进行业朝着更可信、更安全的方向发展。

结论

随着LLM智能体在各行业的应用扩展,其安全性已成为不可忽视的课题。近两年的研究表明,LLM智能体存在从提示词注入、后门投毒到多智能体交互协议的多重攻击面,且现实攻击成功率令人忧虑¹⁵。为此,学术界和工业界提出了多种防护思路,包括沙箱隔离、策略监管、审计追踪以及多智能体内部的信任机制^{9 32}。同时,一系列重要论文和开源项目极大促进了对智能体安全问题的理解和应对,如攻击案例分析⁹、安全基准测评^{68 74}以及通信协议标准的探索⁵⁴等。这些进展为我们打造安全可靠的LLM智能体奠定了基础。然而,挑战依然存在:攻击者的技巧不断翻新,智能体的能力越强潜在滥用后果越严重,这要求我们秉持**纵深防御和持续红队**的原则,在模型、工具、协议各层面构建多道防线,并不断通过自动化评测完善防御体系^{33 64}。展望未来,随着研究的深入,我们有望开发出更加健全的智能体安全框架和行业标准,为LLM智能体的大规模部署保驾护航,确保这一变革性技术能够安全地服务于人类社会。

参考文献:

1. Ferrag et al. From Prompt Injections to Protocol Exploits: Threats in LLM-powered AI Agents Workflows. ICT Express, 2025 14 15 .
 2. Deng et al. AI Agents Under Threat: A Survey of Key Security Challenges and Future Pathways. ACM Computing Surveys 57(7):182, 2025 44 45 .
 3. Zhan et al. Adaptive Attacks Break Defenses Against Indirect Prompt Injection on LLM Agents. arXiv:2503.00061, 2025 15 .
 4. Huang et al. Composite Backdoor Attacks Against Large Language Models. arXiv:2310.07676, 2023 66 .
 5. Zhu et al. DemonAgent: Dynamically Encrypted Multi-Backdoor Implantation Attack on LLM-based Agent. arXiv:2502.12575, 2025 66 .
 6. Positive Security. Hacking Auto-GPT and Escaping its Docker Container. Blog, 2023 9 34 .
 7. Lakera. Prompt Injection & the Rise of Prompt Attacks. Blog, 2025 8 64 .
 8. Jiang et al. Deceiving LLMs through Compositional Instructions with Hidden Attacks. ACM TAAS, 2025 83 .
 9. Schwartz et al. Graph of Attacks with Pruning: Optimizing Stealthy Jailbreak Prompt Generation. arXiv:2501.18638, 2025 84 51 .
 10. Chen et al. AEIA-MN: Evaluating the Robustness of Multimodal LLM-Powered Mobile Agents against Active Environmental Injection Attacks. arXiv:2502.13053, 2025 85 67 .
 11. Yang et al. Watch out for your Agents! Investigating Backdoor Threats to LLM-based Agents. NeurIPS 37, 2024 48 49 .
 12. Yu et al. GPTFuzzer: Red Teaming Large Language Models with Auto-Generated Jailbreak Prompts. arXiv:2309.10253, 2023 50 .
 13. Dong et al. Fuzz-Testing Meets LLM-based Agents: An Automated and Efficient Framework for Jailbreaking Text-to-Image Generation Models. IEEE S&P, 2025 81 .
 14. Huang et al. Jailbreak in Pieces: Compositional Adversarial Attacks on Multi-Modal LLMs. arXiv: 2307.14539, 2023 86 .
 15. OWASP. LLM Prompt Injection Prevention Cheat Sheet, 2023 4 6 .
 16. OpenAI. GPT-4 System Card, 2023. (智能体安全策略讨论)
 17. Jen-tse Huang et al. On the Resilience of LLM-Based Multi-Agent Collaboration with Faulty Agents. ICML 2025 21 22 .
 18. Li et al. CORBA: Contagious Recursive Blocking Attacks on Multi-Agent Systems Based on LLMs. arXiv:2502.14529, 2025 24 25 .
 19. Zhexin Zhang et al. Agent-SafetyBench: Evaluating the Safety of LLM Agents. arXiv:2412.14470v2, 2025 74 75 .
 20. Andriushchenko et al. AgentHarm: A Benchmark for Measuring Harmfulness of LLM Agents. ICLR 2025 68 71 .
 21. Fujitsu. World's first multi-AI agent security technology – Press Release, Dec 12, 2024 87 41 .
 22. Yu et al. A Survey on Trustworthy LLM Agents: Threats and Countermeasures. KDD 2025 (预印本) 88 89 .
 23. Tran et al. Multi-Agent Collaboration Mechanisms: A Survey of LLMs. arXiv:2501.06322, 2025. (多智能体通信综述)
 24. OpenAI. Function Calling and Plugins. 2023. (插件安全机制说明)
 25. NIST. AI Risk Management Framework 1.0, 2023. (提出AI系统安全评估方法)
-

1 2 3 14 15 16 17 18 19 20 33 39 43 46 47 48 49 50 51 52 54 55 56 61 66 67 80 81 83

84 85 86 [2506.23260] From Prompt Injections to Protocol Exploits: Threats in LLM-Powered AI Agents Workflows

<https://arxiv.org/html/2506.23260v2>

4 5 6 7 35 36 37 38 40 53 LLM Prompt Injection Prevention - OWASP Cheat Sheet Series

https://cheatsheetseries.owasp.org/cheatsheets/LLM_Prompt_Injection_Prevention_Cheat_Sheet.html

8 10 11 64 65 82 Prompt Injection & the Rise of Prompt Attacks: All You Need to Know | Lakera – Protecting AI teams that disrupt the world.

<https://www.lakera.ai/blog/guide-to-prompt-injection>

9 34 Hacking Auto-GPT and escaping its docker container | Positive Security

<https://positive.security/blog/auto-gpt-rce>

12 13 Exploiting AI-Agents: Database Query-Based Prompt Injection Attacks in LLM Systems

<https://www.keysight.com/blogs/en/tech/nwvs/2025/07/31/db-query-based-prompt-injection>

21 22 23 28 29 30 31 32 On the Resilience of LLM-Based Multi-Agent Collaboration with Faulty Agents | OpenReview

<https://openreview.net/forum?id=bkiM54QftZ>

24 25 26 27 [2502.14529] CORBA: Contagious Recursive Blocking Attacks on Multi-Agent Systems Based on Large Language Models

<https://arxiv.org/abs/2502.14529>

41 42 62 63 87 Fujitsu develops world's first multi-AI agent security technology to protect against vulnerabilities and new threats : Fujitsu Global

<https://www.fujitsu.com/global/about/resources/news/press-releases/2024/1212-01.html>

44 45 [2406.02630] AI Agents Under Threat: A Survey of Key Security Challenges and Future Pathways

<https://arxiv.org/abs/2406.02630>

57 58 59 60 From prompt injections to protocol exploits: Threats in LLM-powered AI agents workflows - ScienceDirect

<https://www.sciencedirect.com/science/article/pii/S2405959525001997>

68 69 70 71 72 [2410.09024] AgentHarm: A Benchmark for Measuring Harmfulness of LLM Agents

<https://arxiv.org/abs/2410.09024>

73 74 75 76 77 78 79 [2412.14470] Agent-SafetyBench: Evaluating the Safety of LLM Agents

<https://arxiv.org/abs/2412.14470>

88 89 Trustworthy LLM Agents: Threats and Countermeasures | by Adnan Masood, PhD. | Medium

<https://medium.com/@adnanmasood/trustworthy-llm-agents-threats-and-countermeasures-e59fc7552a24>